

Recon-User



تهیه شده توسط تیم TryHackBox

<https://github.com/TryHackBox>

t.me/TryHackBox

<https://youtube.com/@tryhackbox>

Hunter.io

Hunter.io فهرست‌های بزرگی از اطلاعات سازمان‌ها را بر اساس اسکن‌های OSINT که تیمشان انجام می‌دهد، گردآوری می‌کند. این فهرست‌ها شامل نام‌های مخاطبین و آدرس‌های ایمیل و گاهی اوقات شماره تلفن‌ها و عناوین شغلی هستند. بهترین بخش درباره Hunter.io این است که آنها فرمت رایج آدرس ایمیل را برای آدرس‌های ایمیل شناسایی شده نمایش می‌دهند. در یک نگاه می‌توانید فرمت را پیدا کنید و سپس از آن برای ساخت آدرس‌های ایمیل احتمالی برای نام کارمندان یافت شده در مراحل بعدی شناسایی استفاده کنید. متأسفانه دسترسی رایگان به Hunter.io اخیراً به پایان رسیده است. آنها اکنون 10 نتیجه مخاطب و فرمت ایمیل را به صورت رایگان ارائه می‌دهند. اطلاعات مخاطب اضافی نیاز به اشتراک دارد.

- به طور منظم اسکن‌های OSINT انجام می‌دهد و لیست‌هایی از اطلاعات سازمانی جمع‌آوری می‌کند
 - نام فرد، آدرس ایمیل
 - گاهی اوقات شماره تلفن و عنوان شغلی فرد را هم شامل می‌شود
- الگوهای متداول ایمیل را ارائه می‌دهد
 - مثال‌ها: [حرف اول نام].[نام خانوادگی] یا [حرف اول نام][نام خانوادگی]...
- اخیراً این سرویس به یک سرویس پولی تبدیل شده است

در اینجا می‌توانیم نتایج جستجوی Hunter.io برای دامنه sans.org را مشاهده کنیم. Hunter.io 216 نتیجه حاوی نام کارمندان، آدرس‌های ایمیل و (در برخی موارد) شماره تلفن‌ها و عناوین شغلی را بازگرداند. ویژگی عالی دیگر نتایج Hunter.io این است که فرمت ایمیل مشاهده شده را به شما نشان می‌دهد. بر اساس نتایج جستجو، sans.org از فرمت {حرف اول نام}{نام خانوادگی} برای آدرس‌های ایمیل خود استفاده می‌کند. هنگام ترکیب این الگو با اطلاعات جمع‌آوری شده در مراحل دیگر مانند شناسایی لینکدین و تحلیل قرارداد اسناد، می‌توانیم شروع به ساخت لیست‌های رو

The screenshot shows the Hunter.io 'Domain Search' interface. At the top, the domain 'sans.org' is entered in the search bar. Below the search bar, there are filters for 'All', 'Personal', and 'Generic'. The search results show '216 results' and an 'Export in CSV' button. A red box labeled 'Email Address Format' points to the 'Most common pattern' field, which displays '{f}{last}@sans.org'. Below this, there are buttons for 'Communication (13)', 'Support (12)', and 'IT / Engineering (5)'. A red box labeled 'Employee Info' points to a specific result for 'Georgina Davies', showing her title 'Chief Information Security', phone number '+44 78 8293 1829', and email 'gdavies@sans.org'.

به رشدی از آدرس‌های ایمیل معتبر برای حملات مهندسی اجتماعی بعدی کنیم.

خلاصه ای کوتاه :

Hunter.io - اطلاعات مخاطبان (نام، ایمیل، گاهی شماره تلفن و عنوان شغلی) را از طریق اسکن‌های OSINT جمع‌آوری می‌کند .

-این ابزار الگوهای متداول ایمیل سازمان‌ها (مثل [حرف اول نام][نام خانوادگی]) را شناسایی و نمایش می‌دهد .

-دسترسی رایگان به Hunter.io محدود شده و فقط 10 نتیجه در دسترس است؛ اطلاعات بیشتر نیاز به اشتراک دارد .

- فراداده اسناد و اطلاعات لینک‌دین را می‌توان با الگوهای ایمیل Hunter.io ترکیب کرد تا لیستی از آدرس‌های ایمیل معتبر برای حملات مهندسی اجتماعی ایجاد شود.

❖ اگر به دنبال جایگزینی برای Hunter.io هستید، چند ابزار و روش وجود دارد که می‌توانند به شما در پیدا کردن آدرس‌های ایمیل، شناسایی الگوهای ایمیلی و جمع‌آوری اطلاعات تماس افراد و سازمان‌ها کمک کنند:

ابزارهای پولی (جایگزین Hunter.io):

1.Snov.io

❖ لینک snov.io :

<https://snov.io/>

❖ قابلیت‌ها: استخراج ایمیل از دامنه، تأیید اعتبار ایمیل‌ها، و مدیریت کمپین‌های ایمیلی.

TryHackBox

2. RocketReach

❖ لینک rocketreach.co :

<https://rocketreach.co/>

❖ قابلیت‌ها: پیدا کردن ایمیل و شماره تماس مدیران و کارمندان سازمان‌ها.

3. theHarvester (ابزار متن باز برای OSINT)

❖ لینک :

github.com/laramies/theHarvester

❖ قابلیت ها: جمع آوری ایمیل، زیردامنه ها، و اطلاعات از موتورهای جستجو و شبکه های اجتماعی.

4. Skrapp

❖ لینک :

www.skrapp.io

❖ قابلیت ها: استخراج ایمیل از لینکدین و دامنه های سازمانی.

ابزارهای رایگان :

1. PhoneBook.cz (وابسته به تیم ترول سیکوریتی)

❖ لینک :

phonebook.cz TryHackBox

❖ قابلیت ها: جستجوی ایمیل، دامنه، و شماره تلفن های مرتبط با سازمان.

2. Clearbit Connect (نسخه رایگان محدود)

❖ لینک :

connect.clearbit.com

قابلیت‌ها: پیدا کردن ایمیل‌های کارمندان بر اساس دامنه شرکت.

3. VoilaNorbert (جستجوی رایگان ماهانه ۵۰)

❖ لینک :

www.voilanorbert.com

❖ قابلیت‌ها: جستجوی ایمیل با نام و دامنه سازمان.

4. Lusha (نسخه رایگان محدود)

❖ لینک :

www.lusha.com

❖ قابلیت‌ها: استخراج ایمیل و شماره تلفن از پروفایل‌های لینکدین.

روش‌های دستی (بدون ابزار):

جستجوی گوگل :

site:company.com "email" OR "contact" filetype:pdf

بررسی پروفایل‌های لینکدین:

❖ جستجوی کارمندان سازمان و استخراج فرمت ایمیل از بخش «اطلاعات تماس» .

تحلیل متادیتا اسناد عمومی:

❖ دانلود فایل‌های PDF/Word از سایت سازمان و استخراج ایمیل‌ها با ابزارهایی مثل ExifTool.

داده‌های عمومی نشت اطلاعات اعتبارنامه‌ها

هر روز اخبار جدیدی درباره نشت حجم عظیمی از حساب‌های کاربری مشتریان از طریق نقض داده‌های گزارش شده عمومی می‌شنویم. شرکت‌ها اغلب ماه‌ها یا سال‌ها منتظر می‌مانند تا در حالی که پاسخ به حادثه را انجام می‌دهند، نقض را گزارش کنند. مشتریان معمولاً در صورتی مطلع می‌شوند که داده‌های نقض شده در بازارهای دارک وب در حال خرید و فروش باشد. به عنوان پنتستر، ما بین همدردی با شرکت‌هایی که نقض داده را تجربه می‌کنند و چشم‌انداز داشتن گنجینه بزرگی از اطلاعات که در غیر این صورت در دسترس نبود، گیر کرده‌ایم. هنگامی که داده‌ها به صورت عمومی در دسترس قرار می‌گیرند، عمر مفید رمزهای عبور لو رفته معمولاً بسیار محدود است. با این حال، این بدان معنا نیست که آن‌ها معتبر نیستند. کاربران اغلب به رمزهای عبوری که بسیار مشابه هستند پایبند می‌مانند و همچنین آن‌ها را در چندین سایت مجدداً استفاده می‌کنند. حتی اگر رمزهای عبور دیگر معتبر نباشند، آدرس‌های ایمیل تقریباً همیشه معتبر هستند. علاوه بر این، الگوهای رمز عبور می‌توانند از داده‌های لو رفته ظاهر شوند که منجر به حدس زدن موفقیت‌آمیز رمز عبور در مراحل بعدی حمله می‌شود.

- ❖ نفوذ به داده‌ها (Data breaches) روز به روز شایع‌تر می‌شود .
- ❖ بسیاری از این نفوذها ماه‌ها یا حتی سال‌ها گزارش نمی‌شوند .
- ❖ داده‌های سرقتی اغلب در بازارهای تاریک وب (dark web) فروخته می‌شوند یا در انجمن‌هایی که رمز عبورها منتشر می‌شوند، مبادله می‌گردند .
- ❖ از آنجایی که این داده‌ها فقط برای مدت محدودی ارزش دارند، در نهایت به صورت رایگان در دسترس همه قرار می‌گیرند (در بیشتر موارد).
- ❖ یک بازار تخصصی امنیتی در اطراف گزارش دادن نفوذهای دیده شده در طبیعت (در دنیای واقعی) پدید آمده است .
- ❖ حتی اگر سازمانی که قربانی نفوذ شده خواستار تغییر رمز عبور شود، آدرس‌های ایمیل همچنان معتبر باقی می‌مانند .

داده‌های نشت عمومی

خواندن درباره شرکت‌هایی که ده‌ها تا صدها میلیون حساب کاربری آنها نشت کرده خوب است، اما این اعتبارنامه‌ها را کجا پیدا کنیم؟

HavelBeenPwned.com • اولین گزینه عالی است. آنها یک تابع جستجو در وبسایت خود برای آدرس‌های ایمیل فردی ارائه می‌دهند. با این حال، با حدود 3 دلار در ماه، می‌توانید به API دسترسی داشته باشید که امکان جستجو بر اساس نام دامنه ایمیل را فراهم می‌کند. در حالی که نمی‌توانید رمزهای عبور را دانلود کنید، می‌توانید لیست‌های آدرس‌های ایمیل را با استفاده از API آنها به دست آورید.

Dehashed • سایتی است که تعداد زیادی از دامپ‌های داده عمومی را قابل جستجو می‌کند و شامل آدرس ایمیل، نام‌های کاربری و رمزهای عبور خواهند بود. البته برای دسترسی به داده‌ها اشتراک پولی لازم است.

Scylla.sh • یک وبسایت رایگان است که به شما امکان می‌دهد دامپ‌های داده‌ای که نمایه کرده‌اند را جستجو کنید. این سایت ادعا نمی‌کند که همه دامپ‌های داده را دارد، اما تعداد زیادی دارد و قیمت آن مناسب است. به دلیل رایگان بودن سرویس، دسترسی به نتایج ممکن است در زمان بار جستجوی سنگین، نامنظم باشد.

• انجمن‌های دامپ داده عمومی راه دیگری برای به دست آوردن داده‌های نشت یافته هستند. برای تشویق رشد جامعه، آنها اغلب نیاز به ارسال پست برای کسب اعتبار جهت دانلود داده‌های نشت یافته دارند. همچنین می‌توانید اعتبار بخرید و داده‌ها را دانلود کنید. این قطعاً وارد شدن به یک منطقه خاکستری از نظر قانونی است و قبل از شرکت در این انجمن‌ها باید احتیاط کرد.

• در نهایت، تورنت‌هایی با داده‌های موجود وجود دارند. پیدا کردن لینک‌های مربوط به آنچه اینجا ذکر شده را به عنوان تمرین به خواننده واگذار می‌کنم. باز هم، هنگام دانلود این مطالب باید احتیاط کرد.

منابع پیدا کردن Breach data

- HavelBeenPwned.com

❖ سایتی معروف برای بررسی اینکه آیا اطلاعات شما در یک نشت داده قرار داشته است .

- Dehashed.com

❖ یک دایرکتوری آنلاین قدرتمند برای جستجو در داده‌های نشت یافته (نیاز به اشتراک دارد).

- Scylla.sh

❖ سایتی که داده‌های نشت یافته را جمع‌آوری می‌کند و می‌توانید از طریق API یا وب جستجو کنید .

- انجمن‌های عمومی داده‌های نشت یافته (Public data dump forums)
- سایت‌هایی که هکرها یا کاربران، داده‌های سرقتی را منتشر یا به اشتراک می‌گذارند .
- جستجوی دستی در داده‌های عمومی نشت یافته
- با جستجوی ساده در اینترنت، می‌توانید به راحتی به چنین منابعی دسترسی پیدا کنید .
- فایل‌های Torrent
 - فایلی به حجم 77 گیگابایت با عنوان "Leaked Database Archive 7zip file" شامل مجموعه‌ای از داده‌های نشت یافته که در دسترس قرار گرفته است.
 - Archive.org

❖ این سایت داده‌های نشت شده را در مجموعه‌هایی با عنوان "Collections 1-5" در اختیار عموم قرار داده است.

شناسایی نقش‌های کارکنان در سازمان‌ها

لینکدین یک پلتفرم عالی برای انجام شناسایی علیه یک سازمان است. اغلب می‌توانید تقریباً یک چارت سازمانی کامل از هر کارمند را در حین جمع‌آوری نام‌ها، عناوین شغلی و آدرس‌های ایمیل آنها بسازید. علاوه بر این، می‌توانید سازمان‌های خیریه و اهدافی را که سازمان از آنها حمایت می‌کند یا جوایز و تقدیرنامه‌هایی را که شرکت دریافت کرده است، بررسی کنید. تمام این اطلاعات به ایجاد سناریوهای مهندسی اجتماعی در مراحل بعدی زنجیره حمله کمک می‌کنند. متأسفانه، لینکدین از این سوءاستفاده‌ها از پلتفرم خود آگاه شده و سعی می‌کند راه‌های دور زدن را که ما به عنوان پنتستر در هنگام بررسی یک سازمان استفاده می‌کنیم، ببندد. استتار به عنوان کارمندان سازمانی که حساب شما بخشی از آن نیست و همچنین مشاهده پروفایل‌های کارمندان بدون داشتن ارتباط در سازمان آنها، روز به روز دشوارتر می‌شود. راه‌هایی برای دور زدن این محدودیت‌ها وجود دارد، اما آنها نیاز به سرمایه‌گذاری زمان و تلاش برای ساخت پروفایل‌های لینکدین دارند. همانطور که در اسلایدهای بعدی خواهیم دید، هنوز ابزارهایی وجود دارند که می‌توانند در جستجوی لینکدین کمک کنند.

لینکدین هدیه‌ای است که همیشه به‌روز می‌ماند

- ❖ نام کارمندان
- ❖ موقعیت سازمانی / عنوان شغلی
- ❖ آدرس‌های ایمیل
- ❖ پست‌هایی که حاوی اطلاعات مربوط به خیریه‌ها یا اهداف وابسته به هدف‌گیری شده هستند
- ❖ جوازا و افتخارات اخیر

متأسفانه

- ❖ تیم امنیتی لینکدین به‌طور مداوم راه‌های دسترسی به لیست کارمندان سازمان‌ها را می‌بندد
- ❖ در بسیاری از موارد، مشاهده لیست کارمندان نیازمند ارتباطات (Connections)

سناریو مهندسی اجتماعی (حمله هدفمند به یک سازمان):

مرحله ۱: شناسایی تارگت (OSINT با لینکدین)

- جستجوی لینکدین:
 - پیدا کردن مدیر فناوری اطلاعات (IT Manager) سازمان تارگت.
 - استخراج اطلاعات:
 - نام کامل: "رضا محمدی"
 - سمت: "مدیر بخش فناوری اطلاعات در شرکت X"
 - تاریخ‌های فعالیت: "از ۲۰۱۸ تا کنون"
 - مهارت‌ها: "امنیت شبکه، میکروسافت آژور"
- جمع‌آوری اطلاعات تکمیلی:
 - بررسی پست‌های او درباره همایش‌های امنیتی.
 - پیدا کردن ایمیل سازمانی: r.mohammadi@companyX.com: (با فرمت [حرف اول نام].[نام خانوادگی]).

مرحله ۲: ساخت هویت جعلی

- ساخت پروفایل لینکدین فیک:

- نام: نازنین اکبری (با سابقه کاری جعلی در حوزه امنیت اطلاعات).
- اضافه کردن مهارت‌های مشترک با تارگت (مثلاً "آژور")
- اتصال به همکاران دیگر شرکت X برای افزایش اعتبار.
- ساخت ایمیل فیک:
- آدرس n.akbari@tech-conf.org: (با ظاهر رسمی مرتبط با همایش‌های امنیتی).

مرحله ۳: تماس اولیه (پیش‌متن)

- ارسال ایمیل به رضا محمدی:
- موضوع: "دعوت به همایش امنیتی بین‌المللی ۲۰۲۴"
- متن:
- "سلام آقای محمدی،
- با توجه به سابقه شما در حوزه امنیت، مایلیم از شما برای سخنرانی در همایش امسال دعوت کنیم.
- لطفاً برای اطلاعات بیشتر، فایل ضمیمه را بررسی کنید".
- ضمیمه: یک فایل PDF آلوده با ماکرو (حاوی بدافزار متصدی اطلاعات).

مرحله ۴: اجرای حمله

- واکنش تارگت:
- باز کردن فایل PDF و فعال کردن ماکرو (با پیام جعلی "این فایل به دلیل تنظیمات امنیتی قفل شده است.")
- نصب بدافزار روی سیستم سازمان.
- دسترسی مهاجم:
- شناسایی شبکه داخلی از طریق بدافزار.
- سرقت داده‌های حساس مانند لیست کاربران و رمزهای عبور.

مرحله ۵: پاکسازی ردپا

- حذف ایمیل و فایل از صندوق ورودی تارگت.
- غیرفعال کردن حساب‌های جعلی (لینک‌دین/ایمیل).

نکات کلیدی موفقیت حمله:

- تطابق اطلاعات: استفاده از جزئیات واقعی (مثل نام همایش‌هایی که تارگت در آنها حضور داشته).
- فوریت ساختگی: ایجاد حس فوریت ("ثبت‌نام تا ۴۸ ساعت دیگر").
- بهانه‌گیری: اگر تارگت مشکوک شد، بهانه‌ای مثل "اشتباه بخش فنی داده" بدهید.

LinkedInt

لینکدینت ابزاری عالی نوشته شده توسط وینسنت یو برای اسکرپ کردن لینکدین و جمع‌آوری نام کارمندان و آدرس‌های ایمیل است. لینکدینت اصطلاحات جستجو را برای محدود کردن یا گسترش جستجو می‌پذیرد و پیدا کردن شناسه شرکت مورد استفاده توسط لینکدین را خودکار می‌کند. نتایج بیشتر به نتایج حاوی آدرس‌های ایمیل با دامنه سازمان تارگت محدود می‌شوند. پس از اتمام اسکن، یک گزارش HTML حاوی تصویر پروفایل، نام کارمند و آدرس ایمیل تولید می‌شود. لینکدینت به اعتبارنامه‌های معتبر برای یک حساب لینکدین نیاز دارد. هنگام ارائه اطلاعات حساب شخصی لینکدین خود احتیاط کنید، زیرا اسکن گاهی اوقات می‌تواند باعث شود حساب به طور موقت به دلیل اسکرپ کردن مسدود شود. همچنین، اگر حساب هیچ ارتباطی نداشته باشد، نتایج می‌تواند کاهش یابد.

لینکدینت یک ابزار عالی برای جستجو در لینکدین است

❖ نوشته شده توسط وینسنت یو و در دسترس در:

<https://github.com/vysecurity/LinkedInt>

- ❖ این ابزار به طور خودکار شناسه شرکت (Company ID) را پیدا می‌کند.
- ❖ پس از پیدا کردن شناسه شرکت، می‌تواند با استفاده از دامنه ایمیل جستجو کند.
- ❖ امکان استفاده از عبارات جستجوی مختلف برای فیلتر کردن یا گسترش دادن نتایج وجود دارد.

چه چیزهایی برمی‌گرداند؟

- ❖ لیستی از کارمندان شناسایی شده
- ❖ آدرس‌های ایمیل
- ❖ عنوان شغلی گزارش شده

- ❖ برای استفاده از آن به اطلاعات ورود معتبر لینکدین نیاز دارید
- ❖ می‌توانید از یک اکانت موقت (Burner Account) هم استفاده کنید، اما یک اکانت موقت ممکن است نتایج کمتری ارائه دهد، به خصوص اگر تعداد ارتباطات (Connections) کمی داشته باشد.



در اینجا می‌توانیم اصطلاحات جستجوی استفاده شده برای پروفایل کردن SANS با LinkedInt را مشاهده کنیم. ما دامنه ایمیل و فرمت ایمیل [حرف اول نام][نام خانوادگی] را ارائه دادیم. گزینه فرمت ایمیل برای ذخیره فضای اسکرین‌شات کوتاه شده است. در اصل، فرمت ایمیل می‌توانست با استفاده از دسترسی Hunter.io نیز به طور خودکار پیدا شود، اما اکنون این ویژگی پولی شده است. در سمت راست، نمونه‌ای از نتایج را مشاهده می‌کنیم. گزارش تصویر پروفایل، آدرس ایمیل مرتبط با پروفایل لینکدین و عنوان شغلی از پروفایل آنها را نشان می‌دهد. مجدداً، ستون عنوان شغلی برای اندازه اسکرین‌شات حذف شده است. اجرای LinkedInt برای SANS 155 نتیجه بازگرداند.

جمع‌آوری مخاطبین TryHackBox

ابزار عالی دیگر برای شناسایی در لینکدین، افزونه GatherContacts از Burp Suite توسط کری رابرتز است. ویژگی خوب این ابزار این است که می‌تواند نام کارمندان و عناوین شغلی را بدون نیاز به اعتبارنامه لینکدین جمع‌آوری کند. پس از نصب و پیکربندی GatherContacts، به سادگی عبارت [site:linkedin.com/in] سازمان تارگت را جستجو کنید و در نتایج پیمایش کنید GatherContacts. به طور خودکار داده‌های مرتبط را به یک فایل متنی که در حین پیکربندی مشخص شده است، استخراج می‌کند. استفاده از GatherContacts معایبی نیز دارد. برخلاف LinkedInt، شما آدرس‌های ایمیل مرتبط با تارگت را جمع‌آوری نخواهید کرد. عیب دیگر این است که نتایج می‌توانند شامل پروفایل‌های لینکدینی باشد که مستقیماً توسط سازمان هدف استخدام نشده‌اند. اگر پروفایل لینکدین سازمان تارگت را به عنوان کارفرمای قبلی ذکر کرده باشد یا (در مورد SANS) از سرویس‌های آنها استفاده کرده باشد و/یا گواهی‌نامه‌ای از آنها

دریافت کرده باشد، نتایج ممکن است شامل پروفایل‌های کارمندان غیرموجود باشد. این مسئله به ویژه زمانی که تارگت شما یک مؤسسه آموزشی است، شایع‌تر است.

❖ GatherContacts یک افزونه برای Burp Suite است که توسط Carrie Roberts نوشته شده است

❖ در آدرس زیر قابل پیدا کردن است <https://github.com/clr2of8/GatherContacts>

❖ این افزونه نتایج جستجوی لینکدین را از Google و Bing استخراج می‌کند

❖ نیازمند جستجوهای دستی به صورت [site:linkedin.com/in 'سازمان تارگت'] است

❖ نیازی به اطلاعات ورود به لینکدین ندارد

• معایب احتمالی

❖ آدرس ایمیلی فراهم نمی‌کند

❖ نتایج ممکن است شامل پروفایل‌هایی باشد که یا دیگر در سازمان تارگت کار نمی‌کنند یا فقط نام سازمان را در پروفایل خود ذکر کرده‌اند

site:linkedin.com/in "SANS Institute"

Page 2 of about 28,700 results (0.31 seconds)

www.linkedin.com › johnlhubbard

John Hubbard - SANS Institute - LinkedIn

John Hubbard. Certified Instructor and Author @ SANS Institute | On a mission to help you and your team everywhere! SANS InstitutePurdue University, Philadelphia, Pennsylvania - Certified Instructor / Course Author - SANS Institute

www.linkedin.com › wanicha-owen-gisf-43693050

Wanicha Owen, GISF - SANS Institute - LinkedIn

SANS is a leading organization in information security training, the SANS Institute providing intensive, immersion training designed to help you and your team everywhere! SANS Institute Denver, Colorado - Inside Account Manager, GISF - SANS Institute

Column2	Column3	Column6	Column7
Name 1	Name 2	Description 1	Description 2
Johannes	Ullrich	Fellow	SANS Institute
John	Nix	Director, Federal	SANS Institute
Rob	Lee	SANS Institute	LinkedIn www.linkedin.com
Ray	Hawkins	Director	The SANS Institute / GitHub
Jay	Armstrong	Director, SLED Partnerships	The SANS Institute www.linkedin.com
Tim	Conway	ICS	SANS Institute
Brian	Ventura	Certified Instructor	SANS Institute
Benjamin	Wright	SANS Institute	LinkedIn www.linkedin.com
Frank	Kim	Fellow	SANS Institute
Scott	Cassidy	Managing Director	SANS Institute
Steve	Penny	Director	SANS Institute
Howard	Cribbs	CIO	SANS Institute
Wanicha	Owen	SANS Institute	LinkedIn www.linkedin.com
John	Hubbard	SANS Institute	LinkedIn www.linkedin.com

در اینجا نمونه‌ای از نتایج جستجو برای عبارت "site:linkedin.com/in "SANS Institute" را مشاهده می‌کنیم. در حالی که گوگل ذکر می‌کند که 28,700 نتیجه یافت شده است، گوگل فقط به شما اجازه می‌دهد تا 30 صفحه از 10 نتیجه را مرور کنید. پس از آن، نتایج جستجو مسدود خواهد شد. در سمت راست، فایل متنی حاصل به صورت یک فایل داده با جداکننده تب به Microsoft Excel وارد شده است. ستون‌ها نام کارمند، عنوان شغلی و محل کار را نشان می‌دهند. ستون‌های آخر می‌توانند به تعیین اینکه آیا پروفایل لینکدین نتیجه برای شرایط جستجوی شما معتبر است یا خیر کمک کنند.

جمع‌آوری اطلاعات خودکار یا اسکن خودکار

SpiderFoot

اسپایدر فوت یک اسکنر خودکار قابل تنظیم OSINT است که از بیش از ۱۰۰ منبع داده مختلف استفاده می‌کند. برای شروع کار با اسپایدر فوت، فقط نیاز داریم مخزن گیت‌هاب را کلون کنیم، اسکریپت پایتون را اجرا کنیم و ابزار را راه‌اندازی نماییم. برای بهره‌برداری حداکثری از اسپایدر فوت، می‌توان ۴۴ کلید API برای بررسی منابع داده مختلف وارد کرد. از این ۴۴ مورد، فقط ۸ مورد نیاز به اشتراک پولی دارند. اسپایدر فوت را می‌توان در ۴ حالت مختلف اجرا کرد که از اسکن‌های بسیار سریع و بی‌صدا تا بررسی‌های فوق‌العاده دقیق را شامل می‌شود.

- ابزار OSINT متن باز برای جمع‌آوری خودکار اطلاعات، توسط استیو میکالیف توسعه داده شده
- به صورت رایگان در دسترس است <https://github.com/smicallef>
- نیازمند پیکربندی حداقلی و نصب کتابخانه‌های پایتون
- دارای رابط وبی و خط فرمان
- برای بهترین نتایج، می‌توان کلیدهای API مربوط به سایت‌های اطلاعاتی آنلاین را اضافه کرد
- مجموعاً ۴۴ کلید API قابل افزودن است
- بیشتر آنها فقط نیازمند یک آدرس ایمیل تأیید شده برای دسترسی هستند
- گزینه‌هایی برای انجام اسکن‌های سریع تا کامل در دسترس است
- SpiderFoot دارای ۴ پیش تنظیم اسکن است.

• اسکن 'AH' یک اسکن بسیار جامع انجام می‌دهد که شامل بیش از ۱۰۰ منبع داده و اسکن رویه‌ای است؛ به این معنا که هر ذره اطلاعاتی که پیدا می‌شود نیز بررسی می‌گردد. این موضوع می‌تواند باعث شود اسکن‌ها چندین روز زمان ببرند و ممکن است حاوی داده‌های غیرمرتبط باشد.

• اسکن 'Footprint' به دنبال اطلاعاتی درباره مرز شبکه تارگت خواهد گشت و همچنین به دنبال هویت‌های مرتبط مانند آدرس‌های ایمیل و نام کارمندان خواهد بود. این اسکن بسیار سریعتر از اسکن 'All' است اما همچنان ممکن است بسته به اندازه سازمان تارگت، زمانی طول بکشد.

• ماژول 'Investigate' منابع مربوط به لیست‌های بلاک اسپم و بدافزار و همچنین منابع اطلاعاتی مربوط به وبسایت‌های مخرب را برای یافتن اطلاعات درباره تارگت استعلام می‌کند. این اسکن می‌تواند برای پاسخگویان تیم آبی (Blue Team) که در حال بررسی یک هشدار یا گزارش هستند، مفید باشد.

• اسکن 'Passive' تمام ماژول‌هایی را غیرفعال می‌کند که ممکن است با سازمان تارگت تعامل داشته باشند. این اسکن فقط از OSINT خالص برای جمع‌آوری اطلاعات استفاده می‌کند و نباید باعث شود تارگت متوجه اسکن‌های شما شود.

- همه

- این اسکن از تمام ماژول‌های موجود استفاده می‌کند

- زمان زیادی برای تکمیل طول می‌کشد (چند ساعت تا چند روز)

-ردپا

-به دنبال اطلاعات مربوط به لبه شبکه تارگت می‌گردد

-عمدتاً نتایج جستجو در موتورهای جستجو و کاوشگرهای وب است

-بررسی

-انجام ردیابی پایه و استعلام از لیست‌های مسدود و منابع اطلاعاتی بدافزار

-غیرفعال

- هیچ‌گاه به صورت مستقیم از تارگت یا سایت‌های وابسته استعلام نمی‌کند.

TryHackBox

مارا به علاقه‌مندان معرفی کنید آموزش رایگان تست نفوذ و رد تیم .